

Lab 13 - Host de salto



Prof. Dr. Luiz F. Freitas-Gutierrez

luiz.gutierrez@ufsm.br

linkedin.com/in/lffreitas-gutierrez



Lattes

ORCID

SciProfiles

Scopus

ResearcherID

substationworm

LFreitasGutierrez

Resumo do problema

- Realiza uma avaliação interna de segurança de rede para uma organização industrial de fabrico. O ponto de acesso inicial é uma estação de trabalho (corp-pc1) dentro da rede corporativa IT. O objetivo principal é identificar vulnerabilidades ou más configurações de segurança que permitam a um atacante pivotar da rede IT para os sistemas OT-ICS da organização. Não foram fornecidos diagramas de rede, inventários de ativos nem credenciais administrativas.

Tarefas

- **1** Verifica o endereço IP atribuído à estação corp-pc1. OTLab13{XXX.XX.X.XX}
- **2** Determina a subrede de rede à qual corp-pc1 pertence. OTLab13{XXX.XX.X.X/XX}
- **3** A partir de corp-pc1, identifica os endereços IP e a informação do fabricante (MAC OUI) de outros hosts ativos dentro da rede corporativa. OTLab13{XXX.XX.X.XX:<Vendor>,XXX.XX.X.XX:<Vendor>,XXX.XX.X.XX:<Vendor>}
- **4** Identifica pelo menos outra rede alcançável a partir de corp-pc1 inspecionando a tabela de rotas do sistema. OTLab13{XXX.XX.XX.X/XXviaXXX.XX.X.XXXdevethX}
- **5** Para a rede descoberta na tarefa anterior, realiza um scan TCP e identifica portas abertas e serviços expostos. Dica: usa --top-ports 50. Dica: as regras de firewall podem restringir o scan em alguns hosts. OTLab13{XXX.XX.XX.XX:<Port>:<Service>}
- **6** Usando os resultados da tarefa anterior, ganha acesso ao host de salto e localiza a flag escondida dentro dos seus diretórios. OTLab13{Xxxx_Xx_Xxx_Xxxxx}
- **7** Executa um ping sweep com nmap para identificar hosts OT-ICS disponíveis na rede industrial. Reporta os respetivos endereços IP e a informação do fabricante. OTLab13{XXX.XX.XX.XX:<Vendor>,XXX.XX.XX.XX:<Vendor>,XXX.XX.XX.X:<Vendor>}
- **8** Para o dispositivo OT-ICS cujo endereço IP tem dois dígitos idênticos no último octeto, identifica o protocolo industrial em uso e extrai o número de série do dispositivo. OTLab13{XXXxxx,<Serial>}
- **9** Outro host na rede industrial expõe uma interface de gestão web. Explora a interface e recupera a flag protegida. OTLab13{XXXXXXXXXXXXXXXXXXXX}
- **10** Uma mensagem suspeita está a ser transmitida na rede industrial indicando um problema operacional. Interceta a mensagem e identifica remetente, destinatário e conteúdo da mensagem. OTLab13{<Sender_IP>:<Recipient_IP>:XXXXXXXXXXXXX_Xxxxx_Xxx}
- **11** Na DMZ, foi transmitida uma mensagem de estado operacional e armazenada como registo de log. Localiza o registo e identifica o remetente e o conteúdo da mensagem. OTLab13{<Sender_IP>:Xxx_Xxx_Xxxxxx_X_Xx_Xxxxxxx}

Nota: Alguns dispositivos OT-ICS baseiam-se em Conpot, que remapeia portas padrão de protocolos e serviços para portas não privilegiadas. Consulta o link para uma lista de algumas portas padrão e remapeadas.

Ferramentas

- As seguintes ferramentas são recomendadas para completar o OTLab 13: `curl`, `ifconfig`, `ip`, `netdiscover`, `nmap`, `ssh` e `tcpdump`.

Nomenclatura

- DMZ: zona desmilitarizada.
- ICS: sistema de controlo industrial.
- IP: protocolo de Internet.
- IT: tecnologia da informação.
- MAC: controlo de acesso ao meio.
- OT: tecnologia operacional.
- OUI: identificador único organizacional.
- SSH: shell segura.